Tema 4.
Identificación, Autenticación y Autorización (I)

Dr. Rafael Martínez Gasca
Grupo de Investigación **Quivir**,
Tecnologías Inteligentes y de Seguridad de los Sistemas de Información
Departamento de Lenguajes y Sistemas Informáticos
Universidad de Sevilla





Indice

- Implementación de los requisitos de Identificación & Autenticación & Autorización
  - Identificación y Autenticación
    - Gestión de Identidades
    - Biometría, Passwords, Smartcard, Pattern Lock
    - Claves criptográficas. Certificados digitales. PKI
  - Autorización

- **Gestión de Identidades** Incluye el uso de diferentes tecnologías/productos y procesos para **identificar, autenticar, y autorizar a los usuarios a través de medios automáticos (control de acceso).**
  - **Identificación**: Método para establecer la identidad del sujeto (usario, programa, proceso).
  - **Autenticación**: Método para probar la identidad.
    - Algo que una persona **es, tiene, o hace**. Y procesos/programas??
    - Uso de biometría, passwords, palabras de paso, token, u otra información privada..
    - ***Strong Authentication*** contiene ***dos factores de autenticación*** de los tres métodos anteriores

- Verifica una identidad por análisis de ***un atributo de una persona o su comportamiento.***
- Costosa forma de probar la identidad, y con dificultades por el grado de aceptación del usuario.
- Muchos sistemas: Huella, Escaneo de la palma de la mano, Iris Scan, Dinámica de la firma, Dinámica con el Teclado, Captura de Voz, Escaneo Facial, Topografía/Geometría de la mano.
- Problemas de la Biometría. Comparaciones
  - **Error Tipo I:** ***False rejection rate***. (rechaza un usuario autorizado)
  - **Error Tipo II:** ***False acceptance rate***. (acepta a un usuario no-autorizado). Errores importantes a evitar.



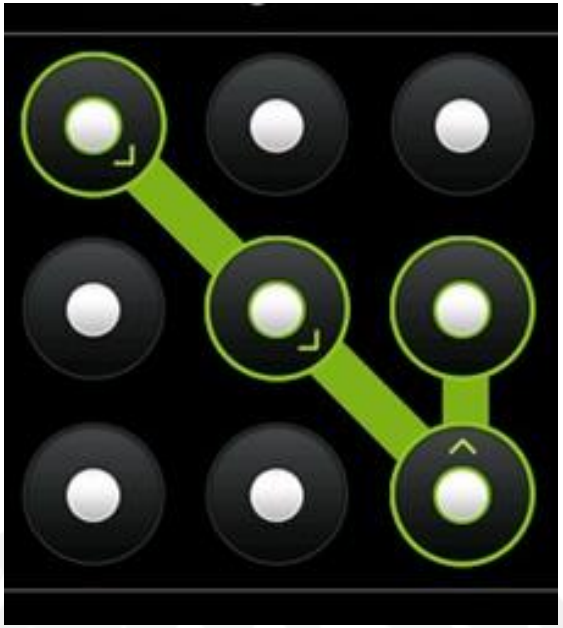
- Débil mecanismo de seguridad, pero muy usado.
  - Necesidad de password robusto a ataques.
    - Evitar 'admin' or 'root' or 'administrator' como login de admin
    - **privado**: usado y conocido solamente por una persona
    - **secreto**: No aparecer en texto plano en cualquier fichero o programa o trozo de papel.
    - **Fácil de recordar**: no es necesario escribirlo en lugar alguno
    - **Complejo (al menos 12 caracteres),** una mezcla de al menos 3 de los siguientes: letras mayúsculas, minúsculas, digitos y símbolos
    - **No adivinable** por cualquier programa en un tiempo razonable. **Regularmente cambiado**: bueno un cambio cada 3 meses
  - Cuidado alguien puede observar cómo lo introduces (Keyloggers software y hardware). Si por accidente colocas el password en vez del login, éste puede aparecer en el fichero de logs.

- Implementar ***Clipping Level***. El administrador puede permitir cierto número de intentos de entrada fallidos antes de ser bloqueado durante un periodo de tiempo.

- Problemas de ataques de passwords
  - Monitorización Electrónica
  - Acceso al fichero de password
  - Ataques de Fuerza Bruta (Ataques de Diccionario)
  - Ingeniería Social
  - Requiere controles de administración efectivos (tamaño, tiempo, límites de fallos)

- **Memory Cards:** Contiene información de autenticación pero no puede procesarla. Requieren un lector y generalmente llevan PIN
- **Smart Cards:** Contiene **información de autenticación y el hardware/software necesario para procesarla**. Pueden ejecutar algoritmos criptográficos. Hay dos categorías:
  - De contacto.
  - Sin contacto tiene una antena que rodea el perimetro de la tarjeta, cuando esta en el campo electromagnético de lector, tiene la energía para dar potencia al chip interno.

Implementación de Autenticación.
Pattern Lock



- Realizar un camino de tamaño 4–9 en una rejilla de 3 x 3
- Facilidad de uso en dispositivos móviles
- Problemas:
  - 389,112 patrones posibles;
  - 456,976 patrones posibles con password alfabéticos de 4 letras (26 en el alfabeto)
  - El atacante puede ver el patrón por la grasa de los dedos en la pantalla.

- Comparativa de los métodos de autenticación

	Biometría	Passwords	Smart Cards	Pattern Lock
Seguridad	**Fuerte**	**Débil**	**Fuerte**	**Débil**
Facilidad de uso	**Fuerte**	**Fácil**	**Medio**	**Fácil**
Implementación	**Difícil**	**Fácil**	**Díficil**	**Fácil**
Trabajo en móviles	**Posible**	**Si**	**No**	**Si**

- La autenticación multifactor mejora la seguridad
- Requiere dos o más de los siguientes elementos de forma independiente:
  - Conocimiento: algo que sólo conoce el usuario (contraseña, PIN,...)
  - Posesión: algo que sólo posee el usuario (dispositivo, teléfono móvil, o una tarjeta del banco,...)
  - Inherencia: algo que el usuario es (verificación biométrica: huella digital, reconocimiento facial, iris ocular,...)
- Ejemplo: autenticación reforzada PSD2 (para realizar operaciones bancarias)

- Contraseña de un sólo uso
- Se basa en un elemento que poseemos
- **Tipos de autenticación OTP**
  - **Autenticación OTP por SMS:** Se recibe una contraseña de un solo uso a tu dispositivo móvil mediante SMS
  - **TOTP (Time-Based One-Time Passcode):** Se debe abrir una aplicación de autenticación en la que encontrarás una contraseña, disponiendo de un tiempo (30-60 segundos) para introducirla antes de que caduque. Variante: **HOTP** (HMAC-Based One-Time Password)
  - **Tokens de hardware:** Un dispositivo físico (no un móvil) muestra una contraseña de un solo uso que te permite acceder

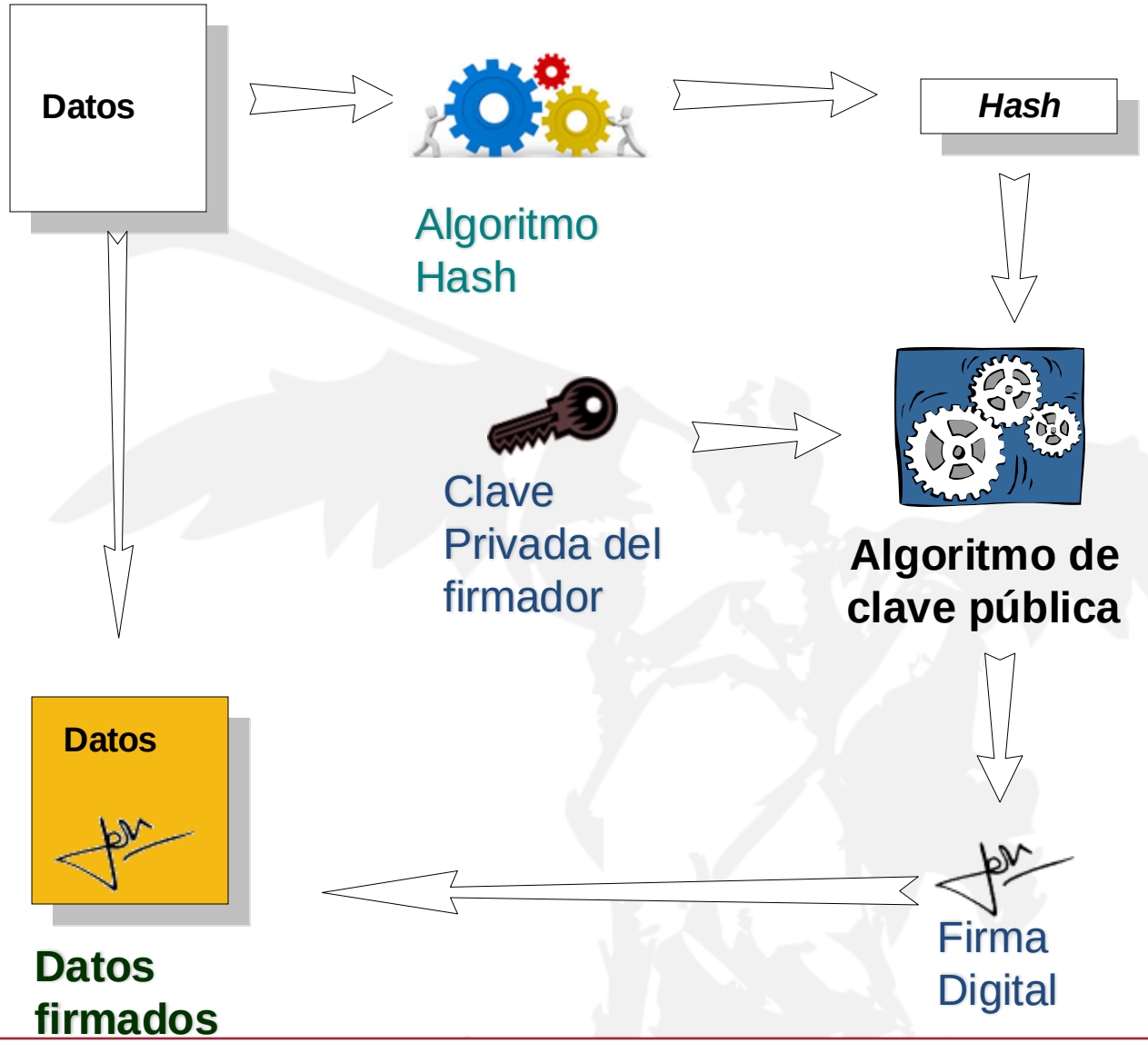
- Problemas de seguridad:
  - El teléfono móvil o dispositivo puede perderse, ser robado o estar en peligro (hace falta alguna protección extra)
  - Los SMS no están cifrados y están vinculados a tu número de teléfono en lugar de a un dispositivo específico (sim SWAP, problemas en el protocolo SS7 que facilita toda la actividad incluidos los mensajes SMS, ...)
  - Una contraseña de un solo uso puede ser robada, la autenticación biométrica es más segura en este aspecto

- Apps: Google Authenticator, FreeOTP, ...
- Utilizan una clave secreta que se comparte a través de una URL o código QR. Debe tener el formato:

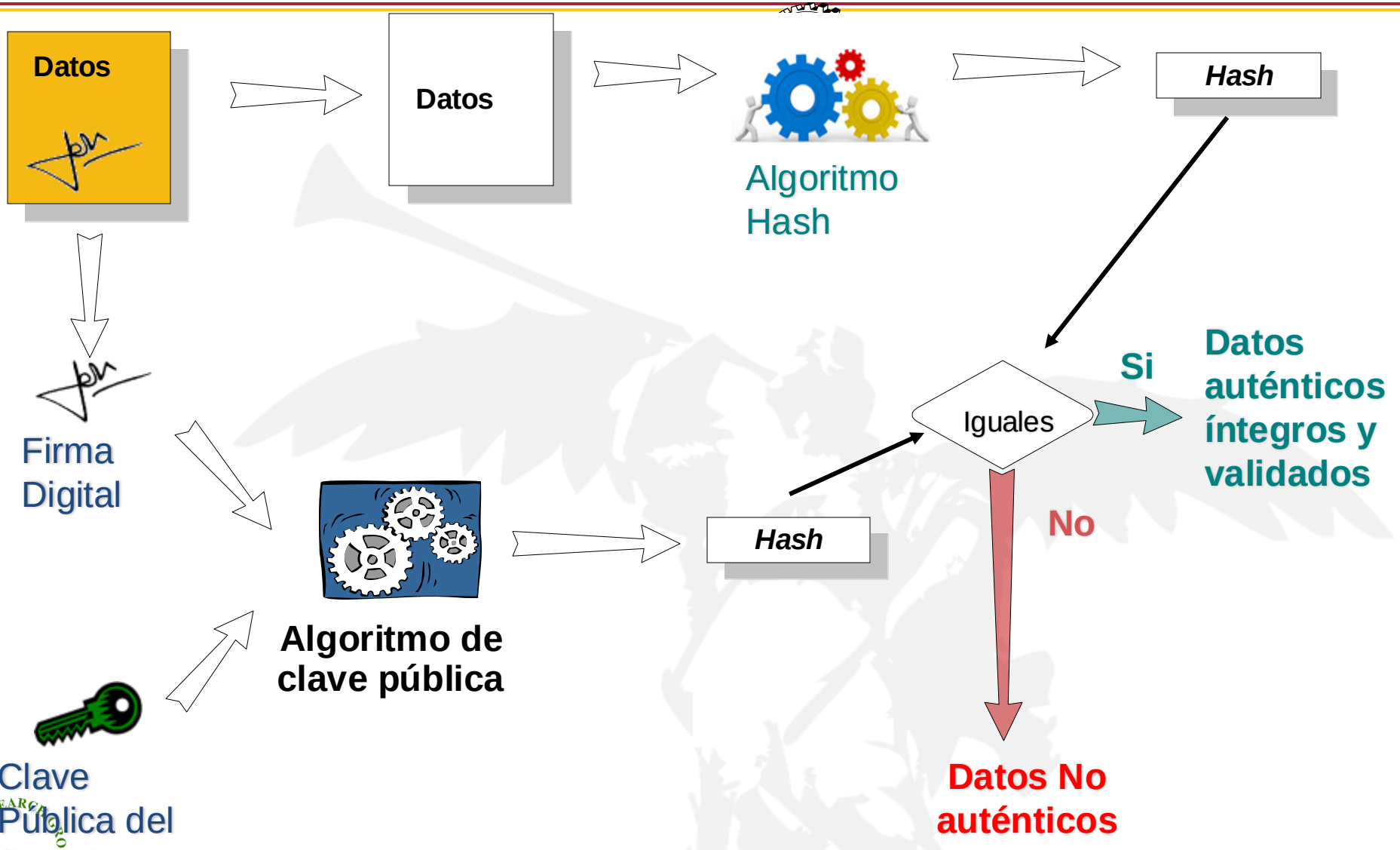
  `otpauth://TYPE/LABEL?PARAMETERS`
- `TYPE: HOTP (contador) o TOTP (tiempo)`
- LABEL: Nombre de la cuenta (accountname), editor (issuer),...
- PARAMETERS:
  - Secret. Codificado en Base32
  - Algorithm: SHA1 (Default), SHA256, SHA512
  - Digits: 6, 8, ...
  - Counter / Period: contador inicial o periodo de tiempo (30 segundos por defecto)

- Claves Criptográficas
  - Uso de **la clave privada** (que no debe proporcionarse a otra persona/aplicación) o **la firma digital** para probar la identidad.
  - No exige presencia física entre las partes implicadas (**Necesita un archivo digital).**
  - **Exige la creación de la firma digital (con la clave privada) y la posterior verificación de la firma (con la clave pública)**
  - **Exige los correspondientes algoritmos de cifrado**
  - **EN 319 122**-1 (CAdES) y **EN 319 132**-1 (XAdES) La primera se basa en el formato clásico PKCS#7. Estándar creado por RSA. Recogido por la IETF (RFC 2315). y la segunda en XML-DSig, que consiste en la firma XML especificada por W3C.

Implementación de Autenticación.
Generación de Firma Básica



Implementación de Autenticación.
Verificación de Firma Básica



- Problemas
  - No es secreto el documento firmado, si hiciera falta:
    - El emisor firma con su clave privada mediante cifrado asimétrico y a continuación cifra el resultado obtenido con la clave pública del receptor también por cifrado asimétrico.
    - El receptor, al recibir el mensaje, lo descifra con su clave privada y vuelve a descifrar el resultado obtenido con la clave pública del emisor.

- La debilidad de las anteriores firmas depende de la seguridad de la clave privada del emisor.
- Si el emisor desea negar el envío de un mensaje, puede afirmar que la clave secreta la ha perdido, que le ha sido robada o que alguien ha falsificado su firma.
- **Solución:** Utilización de un árbitro, una **TTP(tercero de confianza)**. Un notario o un fedatario electrónico

- El emisor envía el documento firmado al tercero para verificar el contenido y el origen garantizando el valor legal de la custodia.
- El tercero usa un servicio de sellado de tiempo en el mismo momento del depósito (generalmente usando una ***Autoridad de de sellos de tiempo (TSA)***, que con su firma electrónica aplicada al documento y tomando una fuente de tiempo confiable, determina la existencia inalterada del documento u objeto desde el momento del sello y con vistas al futuro.
- Se envía al receptor.
- Emisor y receptor deben reconocer la autoridad del tercero.

- Utilización de criptografía de clave pública como un tipo de sistema de identificación de propósito general.
  - Un certificado es una credencial que **relaciona un nombre con una clave pública** (entre otros datos) en un **paquete firmado por una tercera parte confiable**, con un tiempo de validez. (como un pasaporte o un carnet de conducir).
  - Estándar: certificados **X.509 v3** (ITU)
- **Comprobando la firma, uno puede verificar que una clave pública pertenece a un determinado usuario.**

- Tienen los siguientes objetivos:
  - Resolver el problema de la **administración de claves públicas.**
  - Evitar que la **identidad de su dueño pueda ser falsificada**.
- Propone que una tercera entidad intervenga en la administración de las claves públicas.
- Partes más importantes de un certificado digital son:
  - Una clave pública
  - La identidad del implicado: nombre y datos generales.
  - La firma de la tercera entidad (autoridad certificadora) que se reconoce como tal y que **valida la asociación clave pública/identidad.**

- Certificado Digitales en Sistemas Operativos:
  - ***Windows:*** desde línea de comandos invocar ***certmgr.msc***
  - ***Linux:*** *openssl x509 -inform der -in* ***certificado.cer*** *-noout -text*
- ***Certificados Digitales en navegadores***
  - ***Mozilla*** ir a ***Herramientas->Opciones->Avanzado->Certificados***
  - ***Explorer*** ir a ***File*** y despúes a ***Properties.***
  - ***Opera*** ir a ***Herramientas » Opciones » Avanzado » Seguridad » Administrar Certificados***
  - ***Google Chrome*** ir a ***Menú de opciones » Configuración » Mostrar opciones avanzadas » HTTPS/SSL » Administrar Certificados***

Implementación de la Identificación y Autenticación.
Certificados Digitales

¿Cómo obtener un certificado digital de una autoridad de certificación?
¿Cómo anularlo cuando quiera ?

Implementación de la Identificación y Autenticación. PKI

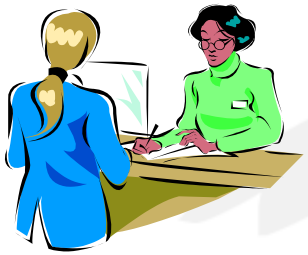
- PKI: Infraestructura de clave pública
  - ***CA*** Autoridad de Certificación, es como las Jefaturas de Tráfico dando certificados y los revocan
  - ***RA*** Autoridades de registro, entidad que comprueba tu identidad
  - ***Clientes*** tienen y usan los certificados
  - ***Repository*** almacena la información de los certificados y el estado, así que no lo tienen que hacer los clients
  - ***VA*** Autoridad de validación es la encargada de comprobar la validez de los certificados digitales

Implementación de la Identificación y Autenticación.
PKI. Infraestructura de clave pública

Autoridad de Certificación

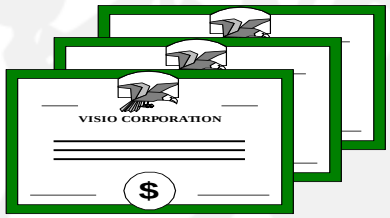


Autoridad de Registro

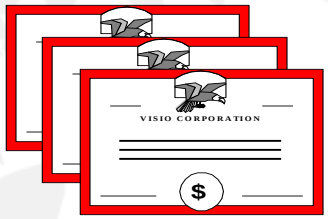




Usuarios



Certificados válidos



Certificados Revocados

Repositorio / Directorio X.509

Implementación de la Identificación y Autenticación.
PKI. Infraestructura de clave pública



- **Solicitar certificado por Internet**
  - Entrar en la página de la autoridad de certificación
  - Seleccionar opción: Obtener certificado de usuario
  - Seleccionar opción: Solicitud vía Internet de su certificado (Introducir el NIF para enviar la petición y seleccionar nivel de seguridad alto, de modo que le pida una contraseña cada vez que utilice el certificado, importante, si utilizan varias personas el mismo ordenador).
  - La autoridad de certificación devuelve un **código de solicitud del certificado** que se debe imprimir.

- **Acreditación de la identidad**
  - El solicitante del certificado deberá presentarse físicamente en una ***Oficina de Acreditación de Certificación Digital*** aportando su Documento Identificativo (DNI o NIF) y el Código de Solicitud que le asignó.
  - Tras la identificación personal, el solicitante firma manualmente el modelo de solicitud del certificado y sus condiciones de utilización, del que se le será entregado una copia.

- **Descargar**
  - Entrar de nuevo en la página web de la autoridad certificadora
  - Pulsar la opción Obtener el certificado de usuario
  - Pulsar la opción: Descarga de su Certificado de Usuario
  - Introducir su NIF además del Código de solicitud de certificado obtenido al solicitar el certificado.
  - Pulsar una vez introducido Descargar
  - Si todo ha ido bien, saldrá un mensaje indicándolo o error en caso contrario.

Implementación de la Identificación y Autenticación.
Certificados Digitales



Certificado de una Entidad

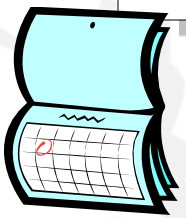
X.509v3

Identificación única del Principal (parte cuya identidad se verifica) del certificado y del distribuidor



Clave Pública del Principal

Nombre del Principal y la Autoridad de Certificación

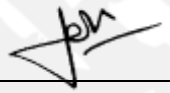


Fechas de expedición y expiración del Certificado

Usos del certificado

Nº de serie: E524 F094 6000 5B80 11D3 3A19 A976 471D

Algoritmo de cifrado empleado para firmar



Firma Digital de la Autoridad Certificadora

- ***¿Confía en la CA?***
- ***¿Es el certificado legítimo?***
  - Obtener la clave pública de la CA; usála para comprobar su firma
- ***¿Es el propietario legítimo?*** Esto requiere un desafío
  - Si es legítimo, debe conocer la clave privada correspondiente a la pública del certificado
  - Tener el certificado no es bastante. Enviarle un ***nonce*** (número aleatorio 128-bit). Si realmente eres el legítimo conoces la clave privada y puedes cifrar el ***nonce***:
    "A87B1003 9F60EA46 71A837BC 1E07B371"
  - Cuando la respuesta vuelve, desciframos usando la clave pública del certificado. Si el resultado coincide al descifrar, el usuario remoto **entonces conoce la clave privada correcta**.
  - Nunca usar el mismo ***nonce*** más de una vez

- Situaciones que pueden invalidar el certificado digital aún cuando no ha caducado, de manera inesperada:
  - El usuario del certificado cree que su clave privada ha sido robada.
  - Desaparece la condición por la que el certificado fue expedido. Por ejemplo, el cambio de apoderado de una entidad jurídica.
  - El certificado contiene información errónea o información que ha cambiado. Por ejemplo, una errata en los apellidos.
  - Una orden judicial.
  - Etc.

Implementación de la Identificación y Autenticación.
Revocación de Certificados

- Empleo de Listas de Revocación de Certificados(CRL) con CA
  - CRL publicadas regularmente y crecen constantemente
  - Puede emitir CRL incrementales (delta CRL) para ahorro en transmisión.
  - **CLR Indirectos** información de revocación de certificados emitidos por entidades diferentes de la que emite la lista de revocación
- Cómo puede hacerse
  - El propietario **emite un certificado de revocación de clave**.
    - La clave privada correspondiente se usa para firmar el certificado.
    - Aconsejable generar un certificado de revocación, cuando se genera un par de claves pública y privada. De esta forma, si se nos olvida la frase de paso, o perdemos la clave privada, siempre podremos revocarlo.